

AI Pen Tester User Guide

Analyze Websites, APIs, Claude Skills, Source Code, and Connected Systems
Version 3.0

CVSS v3.1 scoring · 12 compliance frameworks · Cross-system attack chain detection

For security analysts, developers, and stakeholders

Contents

Part 1 — What This Skill Does

- Five target types at a glance
- What you need before you start

Part 2 — Running an Assessment

- Websites and Claude skills
- API assessments
- Source code reviews
- Connected systems assessments
- Scoping and customisation

Part 3 — Navigating the Report

- Opening and layout
- Severity pills — filter by risk level
- Reachability pills — filter by access path
- CVSS v3.1 score blocks
- Framework filter — 12 compliance frameworks
- Domain pills — filter by review domain (code review only)
- Filter bar, bulk actions, and search
- Finding cards — read, triage, and fix
- Mitigations and artifacts
- Review and export your remediation bundle
- Code-review extras: code excerpts, metrics, footnotes, legend

Part 4 — Connected Systems Report

- Chained Vulnerabilities section
- Compounded Risk section
- Collapsible section headings
- Connected systems export
- Recommended workflow

Appendix — Reference Tables

- A.1 Severity ratings
- A.2 CVSS v3.1 score ranges
- A.3 Reachability ratings
- A.4 Website & skill control families (13 families, 63 controls)
- A.5 API control families (13 families, 53 controls)
- A.6 Code review control families (12 families, 51 controls)

A.7 Cross-system control families (9 families, 27 controls)

A.8 Compliance frameworks (12 frameworks)

A.9 Source framework legend (12 references)

Part 1 — What This Skill Does

The AI Pen Tester skill is a structured security analyser. You give it a target — a website, an API, a Claude skill, or source code — and it methodically tests every applicable security control, calculates CVSS v3.1 scores, maps findings to 12 compliance frameworks, and produces an interactive HTML report with pre-built code fixes you can export directly into your project.

Everything runs inside your Claude session. No data leaves your machine. The skill does not send exploit payloads to live servers; it analyses the code and configuration you provide.

After completing individual assessments, you can optionally run a Connected Systems Assessment to detect multi-step attack chains that span connected systems and re-score findings whose risk changes in a cross-system context.

Five Target Types at a Glance

Target	What gets tested	Controls	Report produced
Website	HTML, JS, headers, cookies, authentication, security configuration	63 controls, 13 families	Interactive Remediation Report
Claude Skill	SKILL.md, tool permissions, prompt injection surface, data handling	63 controls (+ SKILL family)	Interactive Remediation Report
API	REST/GraphQL endpoints, auth, rate limiting, input handling, data exposure	53 controls, 13 families	API Vulnerability Report
Source Code	Python, JavaScript/TypeScript, or Rust files — security, complexity, dev practices	51 controls, 12 families	Code Review Report
Connected Systems	Cross-system attack chains, reachability changes, CVSS re-scoring	27 controls, 9 families	Correlation Report

Individual assessments target **one type at a time**. The Connected Systems Assessment correlates findings from two or more completed assessments in the same session.

What You Need Before You Start

- **The pen-tester skill installed** — the skill folder must contain SKILL.md, assets/, and references/.
- **A target** — a URL, API endpoint/spec, pasted HTML, a SKILL.md path, or source code files.
- **Access** — websites and APIs must be reachable; skills and code must be readable by Claude.

Part 2 — Running an Assessment

Tell the skill what to analyse. It will confirm scope, run every applicable control, calculate CVSS scores, and deliver your report. You do not need to guide each step.

Websites and Claude Skills

Start the assessment with a prompt like one of these:

- *"Run a pen test on `https://example-bank.com`"*
- *"Here's my site's HTML, test it for vulnerabilities"*
- *"Pen test the skill at `./my-skill/SKILL.md`"*
- *"Test these three pages: `/login`, `/admin`, `/dashboard`"*

The skill will then:

1. **Confirm scope** — which controls to test, which report format (HTML, Markdown, or both), and which compliance frameworks to map against.
2. **Profile the target** — technology stack, authentication mechanisms, inputs, headers, cookies, JS libraries (websites) or data access patterns, trust boundaries, tool usage (skills).
3. **Test every in-scope control** — 63 controls across 13 families. Each control is marked COMPLIANT, NON-COMPLIANT, NOT APPLICABLE, or PARTIALLY COMPLIANT.
4. **Calculate CVSS v3.1 scores** — each non-compliant finding receives a Base Score (0.0–10.0) with the full vector string and a reachability rating (DIRECT, ONE_HOP, MULTI_STEP, or INTERNAL).
5. **Classify each finding** — severity level (Critical through Informational) and CIA triad impact (Confidentiality, Integrity, Availability).
6. **Generate the report** — an Interactive Remediation Report (HTML) with pre-built mitigations, and/or a structured Markdown assessment.

Tip: Provide both website code and its associated Claude skill in a single session for the most thorough results. The skill notes which controls apply to which target.

API Assessments

The API assessment covers REST, GraphQL, and similar HTTP-based APIs with controls tailored to API-specific risks including BOLA, mass assignment, rate limiting, and SSRF.

Start with a prompt like:

- *"Pen test my API at `https://api.example.com`"*
- *"Security assessment of my REST API"*
- *"Test this API for OWASP Top 10 issues"*
- *"Check my GraphQL endpoint for vulnerabilities"*

The skill will then:

1. **Confirm scope** — which controls, report format, and compliance frameworks.
2. **Profile the API** — endpoint map, authentication scheme, content types, rate limiting, error handling.
3. **Test every in-scope control** — 53 controls across 13 families including API-specific families (BOLA, Mass Assignment, Rate Limiting, SSRF).
4. **Calculate CVSS v3.1 scores** and assign reachability ratings for each finding.
5. **Generate the report** — an API Vulnerability Report (HTML) with the same interactive UI as the website report.

Tip: Providing an OpenAPI/Swagger spec gives Claude the full endpoint map, parameter types, and authentication schemes — leading to a more thorough assessment than a base URL alone.

Source Code Reviews

The code review covers three domains that together give a complete picture of code health:

- **Secure Code (SEC)** — injection, memory safety, crypto, auth, data protection.
- **Complexity (CPX)** — cyclomatic and cognitive complexity, nesting depth, maintainability.
- **Development Practices (DEV)** — dependencies, testing, linting, CI/CD, build hygiene.

Start it with a prompt like:

- *"Review the code in ./my-project/src for security issues"*
- *"Check my Python files auth.py and payments.py"*
- *"Run a full code review on all TypeScript files"*
- *"Here's my Rust handler, review it for vulnerabilities"*

The skill will then:

1. **Confirm scope** — target files, language(s), which domains to review, and report format.
2. **Profile the codebase** — frameworks, file count, dependency graph, test setup, CI pipeline.
3. **Test every applicable control** — 51 controls across 12 families. Findings include the exact file path, line number, and code excerpt.
4. **Run complexity analysis** — per-function metrics for every function exceeding a threshold.
5. **Generate the report** — a Code Review Report (HTML) with domain-colour-coded findings, CVSS scores, remediation artifacts, and a framework Legend linking each finding to its authoritative source.

Connected Systems Assessments

After completing two or more individual assessments on connected systems (e.g. a website that calls an API), you can ask Claude to correlate findings across systems. This is a post-assessment step — Claude will not run it automatically.

Start with a prompt like:

- *"Analyze how these systems connect"*
- *"Check for cross-system attack chains"*
- *"Run a connected systems assessment"*

- *"How do vulnerabilities in my API affect my website?"*

The skill will then:

1. **Confirm the connection** — which systems are connected and how (e.g. "the website calls the API for authentication").
2. **Identify attack chains** — multi-step exploit paths that combine vulnerabilities across systems (27 controls across 9 families).
3. **Re-score affected findings** — recalculate CVSS scores and reachability ratings for individual findings whose risk changes in a cross-system context.
4. **Generate the report** — a Connected Systems Correlation Report with chain visualisation, compounded risk analysis, and a combined remediation bundle.

Tip: The more individual assessments you complete in a single session, the more cross-system chains Claude can detect. A website + API + code review session gives the richest correlation analysis.

Scoping and Customisation

After you provide a target, the skill confirms three settings. You can accept the defaults or narrow the scope to what matters most.

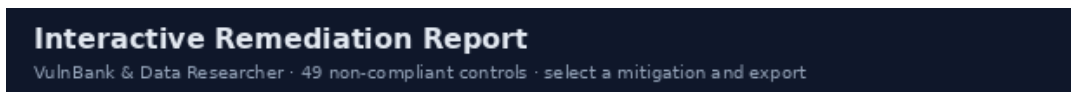
Setting	Default	You can change it to
Controls	All applicable	A specific family (e.g., "only AUTH") or severity ("just CRITICAL")
Report format	HTML + Markdown	HTML only or Markdown only
Frameworks	All 12 mapped	A single framework (e.g., "OWASP only") or a subset

Part 3 — Navigating the Report

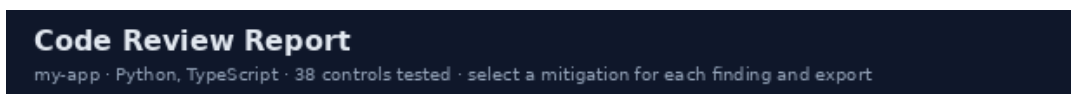
All report types — the Interactive Remediation Report (websites/skills), the API Vulnerability Report, the Code Review Report, and the Connected Systems Correlation Report — are self-contained HTML files with no external dependencies. Double-click to open in any browser. No data is transmitted anywhere.

Nothing is modified. The report does not change any files on your system. "Export" creates new download files. Remediation artifacts are templates for you to review before applying.

Report Layout



Website / Skill report header

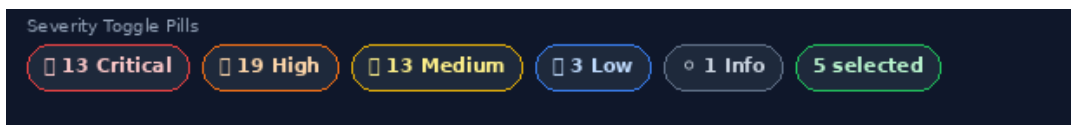


Code Review report header

All reports follow the same top-to-bottom structure:

1. **Header bar** (sticky) — title, summary line, bulk-action buttons.
2. **Toggle pills** — severity pills and reachability pills on all reports; the Code Review report adds domain pills underneath.
3. **Filter bar** — dropdown selectors, framework multi-select, and a keyword search field.
4. **Finding cards** — one per non-compliant control. Click to expand.
5. **Code Review only:** Complexity Summary table and Legend section at the bottom.
6. **Connected Systems only:** Collapsible Chained Vulnerabilities and Compounded Risk sections.

Severity Pills — Filter by Risk Level

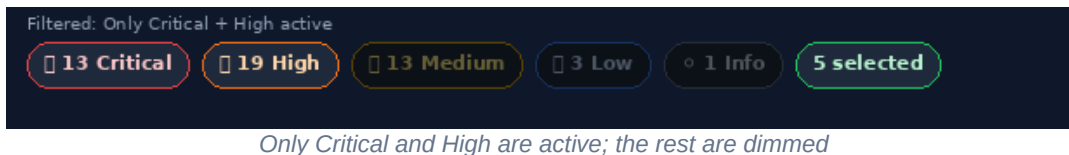


All five severity levels active (default)

Five colour-coded pills sit below the header. Each shows a severity level and its finding count. A sixth green pill tracks how many mitigations you have selected.

How to use them:

- **Click a pill** to hide or show that severity level. Dimmed pills are off.
- **Combine freely.** Turn on only Critical and High to focus on urgent issues.
- Pills work alongside the dropdown filters — set the dropdown to "All" and let the pills control what is visible.



Reachability Pills — Filter by Access Path

Below the severity pills, four reachability pills let you filter findings by how accessible the vulnerability is from an attacker's perspective. Click to toggle, exactly like severity pills.

Rating	Meaning	Typical example
DIRECT	Exploitable from the public internet with no intermediary.	XSS on a public-facing form
ONE_HOP	Requires one intermediate step (e.g. authenticated session).	IDOR requiring a valid session token
MULTI_STEP	Requires chaining multiple conditions or steps.	SSRF that first needs admin access
INTERNAL	Only reachable from internal network or local environment.	Debug endpoint on localhost

CVSS v3.1 Score Blocks

Every non-compliant finding displays a colour-coded CVSS v3.1 block between the metadata grid and the "What was found" section. The block shows:

- **Numeric score** — 0.0 to 10.0, displayed large in a colour matching the severity.
- **Severity label** — Critical, High, Medium, Low, or None based on the score range.
- **Vector string** — the full CVSS v3.1 vector (e.g. CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H) in monospace.
- **Progress bar** — a visual representation of the score out of 10.0.

CVSS scores use the standard v3.1 Base Score metrics: Attack Vector (AV), Attack Complexity (AC), Privileges Required (PR), User Interaction (UI), Scope (S), and the three impact dimensions Confidentiality (C), Integrity (I), and Availability (A).

Note: Code quality findings (complexity thresholds, linting, test coverage) receive a CVSS score of 0.0 because they are not directly exploitable vulnerabilities. The severity level for these findings is determined by their impact on code maintainability rather than security risk.

Framework Filter — 12 Compliance Frameworks

All reports include a multi-select framework filter dropdown. Each finding is mapped to the relevant controls in up to 12 compliance frameworks. Select one or more frameworks to see only findings that map to those standards.

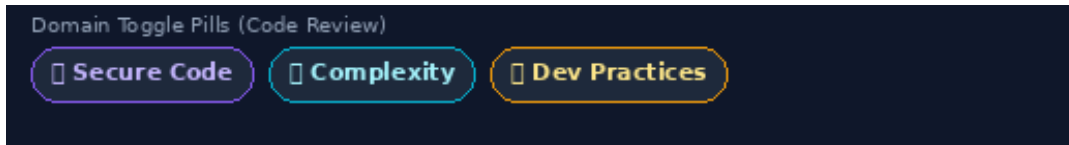
Framework	Full name
-----------	-----------

OWASP	OWASP Top 10 (2025)
NIST	NIST SP 800-53 Rev 5
ISO 27001	ISO/IEC 27001:2022
PCI-DSS	PCI-DSS v4.0.1
SOC 2	SOC 2 Type II Trust Services Criteria
HIPAA	HIPAA Security Rule
CMMC	CMMC v2.0 Level 2
DoD SRG	DoD Cloud Computing SRG
FedRAMP	FedRAMP Moderate Baseline
SEC/FINRA	SEC Reg S-P / FINRA Cybersecurity
EU DORA	EU Digital Operational Resilience Act
EU AI Act	EU AI Act Technical Standards

Framework tags appear on each finding card as small badges. Dimmed badges indicate frameworks not currently selected in the filter. Use "Select all" and "Clear all" buttons in the dropdown for quick toggle.

Domain Pills — Filter by Review Domain

Code Review report only



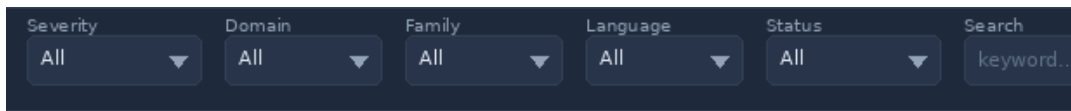
Three domain pills: Secure Code (purple), Complexity (cyan), Dev Practices (amber)

Below the severity pills, three domain pills filter findings by review area. Click to toggle, exactly like severity pills.

- **Secure Code (SEC)** — purple. Injection, memory, crypto, auth, data protection.
- **Complexity (CPX)** — cyan. Structural quality and metric thresholds.
- **Dev Practices (DEV)** — amber. Dependencies, testing, quality, build/deploy.

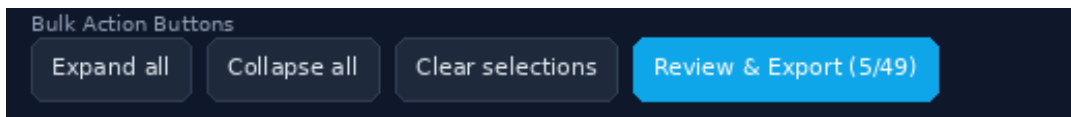
Combine with severity pills for precision: activate only SEC + CRITICAL to see the most urgent vulnerabilities.

Filter Bar, Bulk Actions, and Search



Dropdown filters and keyword search

Filter	What it does
Severity	Narrows to a single severity level. Set to "All" to let the pills control filtering.
Reachability	Narrows to a single reachability rating (Direct, One Hop, Multi-Step, Internal).
Domain	Code Review only. Narrows to SEC, CPX, or DEV.
Family	Narrows to one control family (e.g., AUTH, SEC-INJ, BOLA). Auto-populated from data.
Framework	Multi-select: show findings mapped to specific compliance frameworks.
CIA	Filter by impact dimension: Confidentiality, Integrity, or Availability.
Language	Code Review only. Filters by target language (Python, JS/TS, Rust).
Status	Shows only findings with a selected mitigation, or only those still unaddressed.
Search	Free-text. Matches control ID, name, and finding description. Filters as you type.

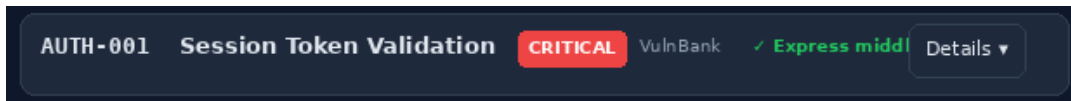


Bulk action buttons in the header

Button	What it does
Expand all	Opens every finding card at once so you can scroll through everything.
Collapse all	Closes all cards back to the compact list.
Clear selections	Removes all chosen mitigations (asks for confirmation first).
Review & Export	Opens the export modal. Counter shows how many findings have a chosen mitigation.

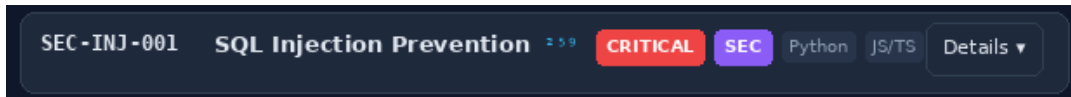
Finding Cards — Read, Triage, and Fix

Website / Skill / API cards



Collapsed card: control ID, name, severity badge, source, and selection status

Code Review cards



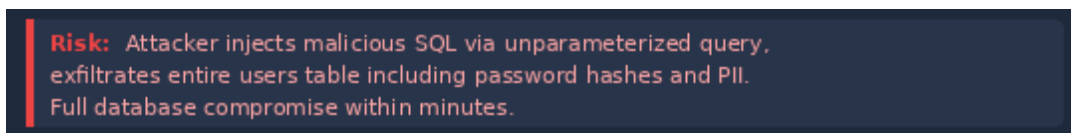
Code review card adds footnote source marks, a domain badge, and language tags

Opening and closing:

- **Click anywhere on the header bar.** The entire bar is a click target.
- The "Details" button works too, but the bar is faster.
- Green border + checkmark = mitigation already chosen for this control.

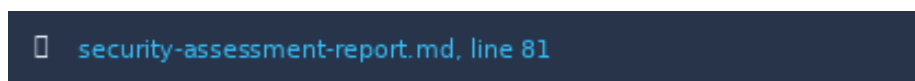
What you see when a card is expanded:

- **Metadata grid** — family, CIA classification, reachability, framework mappings (website/skill/API) or domain and language (code review).
- **CVSS v3.1 score block** — colour-coded score, severity label, vector string, and progress bar.
- **What was found** — the specific non-compliance, with file location and source reference.



Worst-case exploit summary — what happens if the issue is not fixed

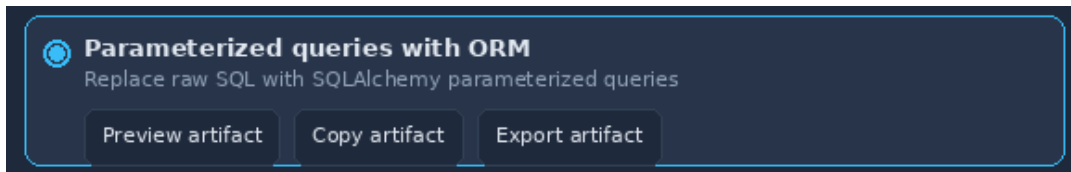
- **Worst-case if unpatched** — a red-bordered box describing the realistic exploit outcome in three lines or fewer. Use this during triage to prioritise, and share it with stakeholders who need to understand risk without reading code.



Source reference linking back to the original assessment document

- **Source reference** (website/skill) — a blue link showing the originating document and line number, so you can cross-reference the full assessment.
- **Candidate mitigations** — two to three remediation options, each with a radio button and artifact action buttons (described next).

Mitigations and Artifacts



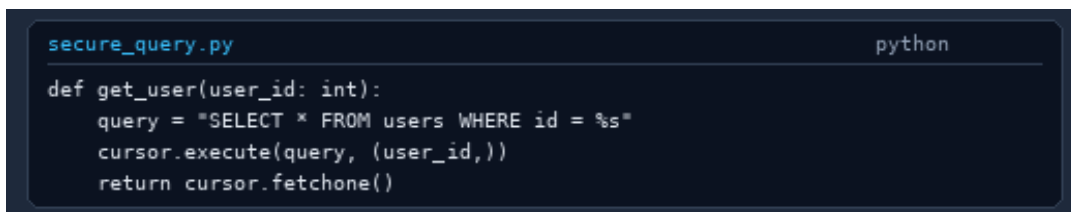
A selected mitigation with its three artifact action buttons

Choosing a mitigation:

1. Expand a finding card.
2. Read the mitigation options — each has a short label and summary.
3. Click the radio button next to your choice.
4. The card border turns green and a checkmark appears in the header.

Change at any time by clicking a different radio button. Only one mitigation per finding. "Clear selections" resets everything.

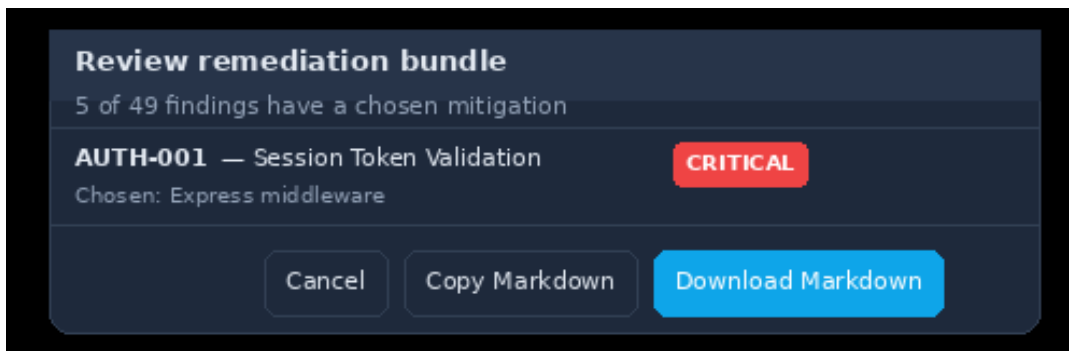
Working with artifacts:



Artifact preview: remediation code with filename and language label

Button	What it does	When to use it
Preview artifact	Shows the full remediation code inline below the mitigation. Click again to hide.	Compare approaches before committing to one.
Copy artifact	Copies the fix to your clipboard. Button briefly shows "Copied!"	Paste a snippet into an existing file.
Export artifact	Downloads the fix as a standalone file with header comments for traceability.	Hand off a complete file to a developer.

Review and Export Your Remediation Bundle



Export modal: review selections, then download as Markdown or JSON

Click the blue **"Review & Export"** button in the header (requires at least one selected mitigation). A modal opens showing every finding where you chose a mitigation.

Export button	Format	Best for
Copy Markdown	Clipboard	Pasting into a ticket, email, or wiki.
Download JSON	JSON file	Feeding into a CI pipeline or tracking tool.
Download Markdown	Markdown file	A complete remediation plan with code blocks — hand it to your team.

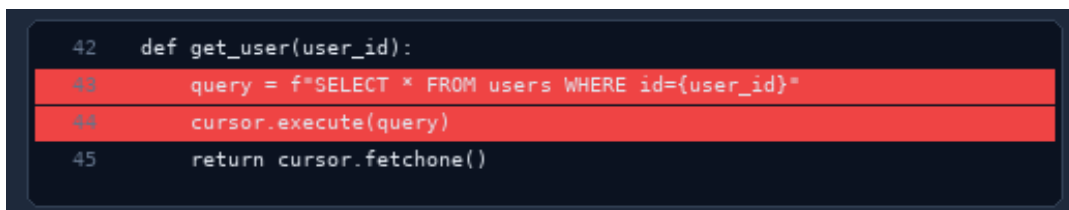
The Code Review export automatically includes the Legend (source framework references) at the end of the bundle.

All exports include CVSS scores and vector strings for each finding.

Code-Review Extras

These features appear only in the Code Review Report.

Code excerpts



Vulnerable code with line numbers — affected lines highlighted in red

Security findings show the exact source code with line numbers. Lines containing the vulnerability are tinted red so they stand out immediately.

Metric values

Value: **18** / Threshold: 10 (Cyclomatic Complexity)

Metric value compared against the threshold

Complexity findings display the measured value next to the threshold. Red means exceeded; green means within range.

Footnote source marks

SEC-INJ-001 SQL Injection Prevention ²⁵⁹ **CRITICAL** **SEC** Python JS/TS Details ▼

Superscript numbers after the control name identify the authoritative source

Each finding card shows superscript numbers (e.g., ²⁵⁹) next to the control name. These identify which framework(s) the control comes from. Scroll to the Legend at the bottom of the report — or see Appendix A.9 — to look up any mark.

Legend section

Legend — Source Framework References

- ¹ **OWASP ASVS 5.0**
(2025) — Application Security Verification Standard
- ² **CWE Top 25**
(2025) — Most dangerous software weaknesses
- ⁷ **McCabe**
(1976) — Cyclomatic Complexity measurement

The Legend maps each footnote mark to its framework name, year, and description

The Legend is always visible at the bottom of the report. It lists all 12 footnote marks with the full framework name, version, and what it covers.

Complexity summary

Below the findings list, a Complexity Summary section lists every function that exceeds a complexity threshold. Columns include cyclomatic complexity, cognitive complexity, nesting depth, lines of code, and Halstead difficulty. Each function receives a verdict: REFACTOR REQUIRED, REVIEW RECOMMENDED, or ACCEPTABLE.

Part 4 — Connected Systems Report

The Connected Systems Correlation Report has a different structure from the individual assessment reports. Instead of a flat list of findings, it organises results into two collapsible sections: **Chained Vulnerabilities** and **Compounded Risk**.

Chained Vulnerabilities

Each chained vulnerability represents a multi-step attack path that combines vulnerabilities from two or more connected systems into a single exploit chain. Chains are displayed with a vertical step-by-step flow showing:

- **System badges** — colour-coded labels identifying which system each step belongs to: **blue** (website), **green** (API), **purple** (skill), **orange** (code).
- **Step sequence** — the action taken and result achieved at each step, connected by arrow indicators.
- **Chain CVSS score** — a compounded CVSS v3.1 score reflecting the combined impact of the full chain.
- **Final impact** — what the attacker achieves when the full chain is executed.
- **Mitigations** — remediation options specific to breaking the chain, with code artifacts.

Example chain: an XSS vulnerability on the website (step 1) steals a JWT token, which is replayed against the API (step 2) to exploit a BOLA vulnerability (step 3), escalating from no access to full admin control.

Compounded Risk

This section lists individual findings from earlier assessments whose CVSS score or reachability rating changes because of the cross-system connection. Each entry shows:

- **Original vs. new CVSS** — side-by-side comparison of the original score and the re-scored value.
- **Original vs. new reachability** — how the access path changed (e.g. INTERNAL to ONE_HOP).
- **CVSS justification** — which vector metrics changed and why (e.g. PR:L changed to PR:N because tokens are stolen via XSS).
- **Reachability justification** — what cross-system path made the finding more (or less) reachable.
- **Chain reference** — which attack chain caused the re-scoring.

Collapsible Section Headings

Both section headings — "Chained Vulnerabilities" and "Compounded Risk" — are clickable. Each shows a live count in parentheses that updates as you apply filters.

- **Click the heading** to collapse or expand that section. A chevron indicator rotates to show state.
- **Amber left border** on the Chained Vulnerabilities heading; **pink left border** on Compounded Risk.
- Counts update dynamically when severity, reachability, family, or framework filters change.

Connected Systems Export

The Review & Export modal in the Connected Systems report works slightly differently from individual assessment reports:

- It lists each chain you selected a mitigation for, with the chain ID, severity, chosen mitigation, and artifact.
- Below the chains, all Compounded Risk entries are included automatically (no selection needed).
- The exported Markdown includes a chain summary table, detailed step-by-step breakdowns, and a compounded risk table with original vs. re-scored values.
- JSON export preserves the full data structure including chain steps, CVSS vectors, and re-score justifications.

Recommended Workflow

Whether you are triaging an individual assessment or a connected systems report, the most efficient pattern is:

1. **Filter to the highest risk.** Turn on only Critical (and SEC for code reviews). Read the worst-case summaries.
2. **Check CVSS scores.** Within a severity level, use the CVSS score to prioritize — a 9.8 Critical needs attention before a 9.0 Critical.
3. **Select mitigations, starting with Critical.** Expand each card, preview the artifact, and pick the best fit for your stack.
4. **Work down the severity levels.** Move to High, then Medium. Use the Status filter ("No selection") to find what you have not addressed.
5. **Export individual fixes as you go.** Use "Export artifact" for controls you can fix immediately.
6. **Generate the full bundle last.** Once every finding has a selection, click Review & Export and download the Markdown file.
7. **Cross-reference.** Use source references (website/skill) or footnote marks (code review) to trace findings back to their origin.
8. **Run Connected Systems last.** After individual assessments, ask Claude to correlate — this may reveal Critical chains that were only Medium individually.

Appendix — Reference Tables

A.1 Severity Ratings

All five report types use the same five-level severity model.

Severity	Meaning	Colour
CRITICAL	Active exploit path to data exfiltration or system compromise.	Red
HIGH	Significant risk, likely exploitable with moderate effort.	Orange
MEDIUM	Moderate risk — requires specific conditions to exploit.	Yellow
LOW	Minor risk. Defence-in-depth improvement.	Blue
INFORMATIONAL	Best practice not followed, but minimal direct risk.	Grey

A.2 CVSS v3.1 Score Ranges

CVSS v3.1 Base Scores map to severity labels as follows:

Score range	Severity	Colour
9.0 – 10.0	Critical	Red
7.0 – 8.9	High	Orange
4.0 – 6.9	Medium	Yellow
0.1 – 3.9	Low	Blue
0.0	None	Grey

The vector string encodes eight metrics: Attack Vector (AV), Attack Complexity (AC), Privileges Required (PR), User Interaction (UI), Scope (S), Confidentiality (C), Integrity (I), and Availability (A). Example: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H = 9.8 Critical.

A.3 Reachability Ratings

Each finding receives a reachability rating describing how accessible the vulnerability is:

Rating	Description	Colour
DIRECT	Exploitable from the public internet with no intermediary.	Rose
ONE_HOP	Requires one intermediate step (e.g. valid session).	Purple
MULTI_STEP	Requires chaining multiple conditions or exploit steps.	Teal
INTERNAL	Only reachable from internal network or local environment.	Indigo

A.4 Website & Skill Control Families

63 controls across 13 families. Mapped to all 12 compliance frameworks.

Family	Code	Focus
Authentication	AUTH	Login, credentials, MFA, brute-force protection
Authorization	AUTHZ	RBAC, privilege escalation, IDOR, API auth
Cryptography	CRYPTO	TLS, key management, password hashing, secrets
Input Validation	INPUT	XSS, SQL injection, CSRF, file upload
Session Mgmt	SESSION	Token generation, cookie flags, timeout, logout
Security Headers	HEADERS	CSP, HSTS, X-Frame-Options, Referrer-Policy
Error Handling	ERROR	Stack traces, generic messages, info leakage
Secrets Mgmt	SECRETS	Hardcoded secrets, env vars, HTTP exposure
Logging/Audit	AUDIT	Event logging, tamper evidence, auth failures
Data Protection	DATA	PII minimization, masking, retention
Skill Security	SKILL	Prompt injection, tool permissions, scope limits
Components	COMP	Known CVEs, SRI, dependency management
Infrastructure	INFRA	Rate limiting, deployment hardening

A.5 API Control Families

53 controls across 13 families. Includes API-specific families for BOLA, mass assignment, SSRF, and rate limiting.

Family	Code	Focus
Auth & Identity	AUTH	API key management, OAuth, JWT, token lifecycle
Authorization	AUTHZ	BOLA, BFLA, object/function-level access
Input Validation	INPUT	Injection, schema validation, parameter pollution
Mass Assignment	MASS	Unprotected property binding, allowlist enforcement
Rate Limiting	RATE	Throttling, quotas, DDoS protection
Data Exposure	DATA	Excessive data return, PII filtering, field selection
Error Handling	ERROR	Stack traces, error code enumeration, info leakage
SSRF	SSRF	URL validation, internal network access, redirect chains

Security Config	CONFIG	CORS, TLS, HSTS, content types, debug endpoints
Logging	AUDIT	API request logging, tamper evidence, monitoring
Cryptography	CRYPTO	TLS enforcement, token signing, key rotation
Injection	INJ	SQL/NoSQL injection, GraphQL injection, command injection
Resource & Infra	INFRA	Pagination, timeouts, deployment hardening

A.6 Code Review Control Families

51 controls across 12 families in three domains. Each control specifies which languages it applies to.

Family	Code	Domain	Count	Focus
Injection Prevention	SEC-INJ	SEC	6	SQL injection, XSS, command injection, path traversal
Memory & Resource	SEC-MEM	SEC	6	Buffer overflow, use-after-free, resource leaks, unsafe blocks
Cryptography	SEC-CRYPTO	SEC	4	Weak algorithms, hardcoded keys, insecure random, TLS
Authentication	SEC-AUTH	SEC	3	Password storage, token validation, session management
Data Protection	SEC-DATA	SEC	4	PII exposure, logging secrets, sensitive data in URLs
Structural	CPX-STRUCT	CPX	5	Function length, nesting depth, parameter count, class size
Metrics	CPX-METRIC	CPX	4	Cyclomatic complexity, cognitive complexity, Halstead metrics
Maintainability	CPX-MAINTAIN	CPX	4	Maintainability index, comment ratio, dead code, duplication
Dependencies	DEV-DEP	DEV	4	Lock files, pinning, vulnerability scanning, license audit
Testing	DEV-TEST	DEV	3	Test coverage, security tests, mutation testing
Code Quality	DEV-QUAL	DEV	4	Linters, formatters, type checking, documentation
Build & Deploy	DEV-BUILD	DEV	4	CI pipeline, SAST integration, secret scanning, reproducibility

A.7 Cross-System Control Families

27 controls across 9 families. Used in Connected Systems Assessments to detect multi-step attack chains.

Family	Code	Count	Focus
Chain Detection	CHAIN	5	Auth token relay, data poisoning, privilege escalation chains, SSRF-to-internal
Trust Boundaries	TRUST	5	Shared auth providers, implicit trust, shared secrets, certificate pinning
Re-Scoring	RESCORE	3	Reachability promotion, CVSS elevation, impact amplification
Data Flow	DATAFLOW	4	Cross-system PII flow, logging correlation, data validation gaps
Session Mgmt	SESSION	2	Cross-system session binding, token scope leakage
Cryptography	CRYPTO	2	Shared key material, cross-system TLS gaps
Configuration	CONFIG	2	Environment drift, shared configuration secrets
Incident Response	INCIDENT	2	Cross-system detection gaps, correlated logging
Supply Chain	SUPPLY	2	Shared dependencies, transitive vulnerability propagation

A.8 Compliance Frameworks

All findings are mapped to the relevant controls in these 12 frameworks:

Framework	Version	Scope
OWASP Top 10	2025	Top web application and API security risks
NIST SP 800-53	Rev 5	Federal security and privacy controls catalogue
ISO/IEC 27001	2022	Information security management system (Annex A)
PCI-DSS	v4.0.1	Payment card industry data security standard
SOC 2	Type II	Trust services criteria (security, availability, confidentiality)
HIPAA	Security Rule	Protected health information safeguards
CMMC	v2.0 Level 2	Cybersecurity maturity model for DoD contractors
DoD SRG	Cloud SRG	DoD cloud computing security requirements guide
FedRAMP	Moderate	Federal risk and authorization management baseline
SEC/FINRA	Reg S-P	Financial industry cybersecurity and privacy rules
EU DORA	2025	Digital operational resilience for financial entities
EU AI Act	2025	AI system security and transparency requirements

A.9 Source Framework Legend

Every code review finding carries superscript footnote marks. This table maps each mark to its authoritative source.

Mark	Source	Version / Year	What it covers
1	OWASP ASVS	5.0 (2025)	Application security verification requirements (17 chapters)
2	CWE Top 25	2025	Most dangerous software weaknesses (MITRE/CISA, 39 080 CVEs)
3	SEI CERT	Current	Secure coding rules for C, C++, Java (Carnegie Mellon)
4	NIST SSDF	SP 800-218 Rev 1 (2025)	Secure software development practices
5	OWASP Top 10	2025	Top web application security risks
6	ISO/IEC 25010	2023	Software quality model — maintainability and reliability
7	McCabe	1976	Cyclomatic complexity — linearly independent paths
8	Cognitive Complexity	SonarSource (2017)	Human-readable complexity — penalises nesting
9	OWASP Secure Coding	Quick Ref (2024)	Checklist: input validation, output encoding, auth, crypto
10	Rust Safety	Rustonomicon (current)	Ownership, borrowing, lifetimes, unsafe block auditing
11	PEP Standards	PEP 8 / 484 / 526 / 257	Python style, type hints, variable annotations, docstrings
12	NIST SP 800-53	Rev 5 (current)	Security and privacy controls catalogue

AI Pen Tester v3.0 User Guide. Covers all five report types: Interactive Remediation Report (websites and skills), API Vulnerability Report, Code Review Report, and Connected Systems Correlation Report. For the full controls libraries, see [controls-library.md](#), [api-controls.md](#), [code-review-controls.md](#), and [cross-system-controls.md](#) in the [pen-tester/references/](#) directory.